



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

PROYECTO INDIVIDUAL

Autor (es):

Quezada Gallardo, Angelo Diancarlo – aquezadag1@miumg.edu.gt

Sosa Arroyo, Danny Josué – dsosaa1@miumg.edu.gt

Girón Rodríguez, Katherine Mishell - kgironr5@miumg.edu.gt

Arango Garcia, Josue David - jgarciaa53@miumg.edu.gt

Salazar Nájera, Javier Eduardo - jsalazarn@miumg.edu.gt

Profesor

CESAR GIOVANNI RODRIGUEZ MINAS

Curso

SEGURIDAD DE SISTEMAS INFORMÁTICO

Guatemala, 2026

Tabla de Contenido

Introducción.....	1
Desarrollo.....	2
Análisis Individual de los Modelos MAGERIT y OCTAVE	2
Modelo MAGERIT: Estructura, Fases y Aplicación Práctica	2
Origen, Propósito y Objetivos del Modelo	2
Estructura del Modelo MAGERIT	3
Fases del Modelo: Análisis y Gestión de Riesgos	5
Aplicación Práctica del Modelo	7
Modelo OCTAVE Allegro: Enfoque Organizacional y Priorización de Activos .	8
Definiciones Principales	8
Enfoque Organizacional.....	9
Priorización de Activos.....	9
Proceso: las Cuatro Fases y Ocho Pasos de Allegro	10
Desempeño General y Casos de Uso.....	11
Estudio de Conceptos Clave: Activos, Amenazas, Vulnerabilidades y Brechas	11
Fundamentos de Gestión de Riesgos en Seguridad Informática	11
Identificación y Clasificación de Activos Informáticos	12
Concepto de Activo	12
Metodología de Identificación	13
Taxonomía según MAGERIT	14
Clasificación según OCTAVE Allegro	15
Criticidad de los Activos: Valor, Impacto en el Negocio y Confidencialidad ...	15
Valor del Activo	16
Dimensiones de Valoración	16
Impacto en el Negocio	17
Confidencialidad como Criterio Crítico	18
Determinación de la Criticidad	18
Amenazas, Vulnerabilidades, Brechas y Criticidad	19
Concepto de Amenaza.....	20
Concepto de Vulnerabilidad	20
Relación entre Amenaza, Vulnerabilidad y Riesgo	21

Metodología de Identificación	22
Clasificación de las Amenazas	23
Taxonomía según MAGERIT	23
Enfoque de OCTAVE Allegro	24
Amenazas de Origen Interno	25
Perfiles del Actor Interno	26
Amenazas de Origen Externo	28
La Frontera Difusa entre el Origen Interno y el Externo	30
Vulnerabilidades: Tipología y Valoración de la Criticidad	31
Tipología de Vulnerabilidades	31
Valoración de la Criticidad de una Vulnerabilidad	32
Correspondencia entre Vulnerabilidades y Amenazas	34
Comparación entre el Origen Interno y el Origen Externo	34
Conclusiones	37
Referencias	39
Anexos	41

Índice de Tablas

Elementos fundamentales del análisis de riesgos en MAGERIT	4
Dimensiones de valoración de la seguridad en MAGERIT	4
Tareas del Método de Análisis de Riesgos (MAR).....	6
Fases y pasos del proceso OCTAVE Allegro.....	10
Clasificación de activos según MAGERIT	14
Escala de valoración de activos	16
Dimensiones de valoración de activos	17
Ejemplo de determinación de criticidad.....	19
Taxonomía de amenazas según MAGERIT v3	23
Componentes del perfil de amenaza en OCTAVE Allegro	25
Perfiles del actor de amenaza interna	26
Amenazas de origen externo más frecuentes	28
Tipología de vulnerabilidades y capa de defensa asociada	31
Criterios para valorar la criticidad de una vulnerabilidad.....	32
Comparación entre amenazas de origen interno y de origen externo	35
Ejemplo de perfil de activo de información (OCTAVE Allegro).....	41
Ejemplo de mapa de contenedores (OCTAVE Allegro)	42

Introducción

El presente trabajo desarrolla, de manera individual, los fundamentos conceptuales y metodológicos que sustentan la gestión de riesgos en seguridad informática, como preparación para el proyecto grupal del curso. El análisis de riesgos no comienza con la tecnología sino con dos preguntas encadenadas: qué puede ocurrirle a lo que la organización necesita proteger, y qué debilidad haría posible que eso ocurriera.

Con ese propósito, la investigación se organiza en dos grandes bloques de contenido. El primero examina de forma individual los dos modelos de gestión de riesgos de mayor referencia en el ámbito de la seguridad de la información: MAGERIT, desarrollado por el Consejo Superior de Administración Electrónica del Gobierno de España, y OCTAVE Allegro, desarrollado por el CERT del Software Engineering Institute de la Universidad Carnegie Mellon. De cada modelo se estudian su origen, su estructura documental, sus fases y su aplicación práctica mediante un ejemplo aplicado a una micro o pequeña empresa, organización de referencia adoptada para todo el trabajo.

El segundo bloque profundiza en los conceptos clave que ambos modelos comparten: la identificación y clasificación de los activos informáticos, la determinación de su criticidad, y la definición y clasificación de las amenazas y vulnerabilidades también llamadas brechas que los afectan, con especial atención a la distinción entre su origen interno y externo, distinción que resulta determinante para la selección de controles eficaces.

El dominio conceptual de estos temas constituye el insumo indispensable para las etapas posteriores del proyecto grupal, ya que sin conocer qué activos existen, cuál es su valor, qué amenaza a cada uno y por dónde es alcanzable, ninguna estimación de impacto, probabilidad o riesgo tendría fundamento.

Desarrollo

Análisis Individual de los Modelos MAGERIT y OCTAVE

Esta sección desarrolla de manera individual los dos modelos de gestión de riesgos objeto de la investigación: MAGERIT, de origen público y adopción principalmente europea, y OCTAVE Allegro, de origen académico y enfoque organizacional. Ambos se examinan desde su origen y propósito, su estructura conceptual, sus fases operativas y su aplicación práctica.

Modelo MAGERIT: Estructura, Fases y Aplicación Práctica

Dentro del estudio de los modelos de gestión de riesgos informáticos, MAGERIT ocupa un lugar de referencia por su enfoque metódico, su carácter público y su amplia adopción en el ámbito de la Administración pública española. Este apartado profundiza en el modelo desde tres perspectivas complementarias: su estructura conceptual y documental, las fases que ordenan el análisis y la gestión de riesgos, y su aplicación práctica en proyectos reales. El objetivo es ofrecer una base clara que permita comprender cómo MAGERIT identifica activos, valora amenazas y vulnerabilidades, estima el impacto y el riesgo, y define las salvaguardas necesarias para mantener la seguridad de la información dentro de niveles aceptables.

Origen, Propósito y Objetivos del Modelo

MAGERIT es el acrónimo de Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Fue elaborada por el Consejo Superior de Administración Electrónica del Gobierno de España, con el fin de sistematizar el análisis y la gestión de los riesgos derivados del uso de las Tecnologías de la Información y la Comunicación. Se trata de una metodología de carácter público, de uso libre y sin autorización previa, lo que ha favorecido su adopción tanto en organismos públicos como en el sector privado (Ministerio de Hacienda y

Administraciones Públicas, 2012a). La versión vigente es MAGERIT v3, publicada en 2012 y aún en uso como referencia en proyectos de seguridad de la información.

En su concepción, MAGERIT se alinea con los estándares internacionales de gestión de riesgos. Siguiendo la terminología de la norma ISO 31000, la metodología materializa el «Proceso de Gestión de Riesgos» dentro de un «Marco de Gestión de Riesgos», y resulta complementaria a la norma ISO/IEC 27005, que ofrece directrices para la gestión de los riesgos de seguridad de la información. Asimismo, constituye una referencia habitual para las organizaciones que deben cumplir el Esquema Nacional de Seguridad.

Los objetivos que persigue la metodología pueden resumirse en cuatro: concienciar a los responsables de las organizaciones sobre la existencia de riesgos y la necesidad de gestionarlos a tiempo; ofrecer un método sistemático para analizar los riesgos derivados del uso de las TIC; ayudar a descubrir y planificar el tratamiento oportuno para mantener los riesgos bajo control; y preparar a la organización para procesos de evaluación, auditoría, certificación o acreditación, según corresponda (Ministerio de Hacienda y Administraciones Públicas, 2012a).

Estructura del Modelo MAGERIT

La estructura de MAGERIT se organiza en tres libros, cada uno con una función específica dentro del proceso de análisis y gestión de riesgos. El Libro I, Método, describe el método propuesto para el análisis de riesgos, el proceso de gestión de riesgos, la formalización de los proyectos de análisis, el plan de seguridad y la integración de la seguridad en el desarrollo de sistemas. El Libro II, Catálogo de Elementos, aporta un inventario normalizado de tipos de activos, dimensiones y criterios de valoración, amenazas típicas y salvaguardas, de modo que el analista no parta de cero. El Libro III, Guía de Técnicas, reúne técnicas de apoyo análisis mediante tablas, análisis algorítmico, árboles de ataque, técnicas gráficas y de planificación útiles para ejecutar las distintas tareas del método (Ministerio de Hacienda y Administraciones Públicas, 2012c).

Sobre esta base documental, el modelo articula seis elementos fundamentales que se relacionan entre sí durante el análisis, sintetizados en la Tabla 1.

Tabla 1. Elementos fundamentales del análisis de riesgos en MAGERIT

Elemento	Descripción
Activos	Recursos del sistema de información con valor para la organización (datos, servicios, software, equipos, comunicaciones, personal e instalaciones).
Amenazas	Eventos que pueden ocurrir sobre los activos y causar un perjuicio a la organización.
Vulnerabilidades	Debilidades o brechas de un activo que una amenaza puede aprovechar para materializarse.
Salvaguardas	Medidas de protección (técnicas u organizativas) que reducen la probabilidad o el daño de las amenazas.
Impacto	Daño sobre el activo derivado de la materialización de una amenaza.
Riesgo	Impacto ponderado con la frecuencia o expectativa de materialización de la amenaza.

Nota. Elaboración propia a partir de Ministerio de Hacienda y Administraciones Públicas (2012a).

Para valorar los activos, MAGERIT emplea cinco dimensiones de seguridad, identificadas con códigos oficiales en el Libro II. Cada activo recibe una valoración en cada dimensión, habitualmente en una escala numérica (de 0 a 10) o cualitativa (bajo, medio, alto), como se presenta en la Tabla 2.

Tabla 2. Dimensiones de valoración de la seguridad en MAGERIT

Código	Dimensión	Qué protege
[D]	Disponibilidad	Que los servicios y datos estén disponibles cuando se necesitan.
[I]	Integridad	Que los datos se mantengan completos y correctos, sin manipulación.
[C]	Confidencialidad	Que la información solo sea accesible a quienes están autorizados.
[A]	Autenticidad	Que una entidad sea quien dice ser y que se garantice el origen de los datos.

Código	Dimensión	Qué protege
[T]	Trazabilidad	Que sea posible saber quién accede a los datos y quién presta los servicios.

Nota. Elaboración propia a partir de Ministerio de Hacienda y Administraciones Públicas (2012b).

El Catálogo de Elementos completa esta estructura clasificando los activos en categorías entre ellas datos e información [D], servicios [S], aplicaciones o software [SW], equipos informáticos [HW], redes de comunicaciones [COM], soportes de información, equipamiento auxiliar, instalaciones y personal y agrupando las amenazas en cuatro grandes tipos: desastres naturales [N], de origen industrial [I], errores y fallos no intencionados [E] y ataques intencionados [A] (Ministerio de Hacienda y Administraciones Públicas, 2012b).

Fases del Modelo: Análisis y Gestión de Riesgos

El núcleo de MAGERIT v3 es el Método de Análisis de Riesgos, que proporciona una secuencia sistemática para determinar el riesgo. En su nivel conceptual, el método sigue cinco pasos encadenados: determinar los activos relevantes para la organización, sus interrelaciones y su valor; determinar las amenazas a las que están expuestos esos activos; determinar las salvaguardas dispuestas y cuán eficaces son frente al riesgo; estimar el impacto, definido como el daño sobre el activo derivado de la materialización de una amenaza; y estimar el riesgo, entendido como el impacto ponderado con la tasa de ocurrencia de la amenaza (Ministerio de Hacienda y Administraciones Públicas, 2012a).

Una particularidad del método es que distingue entre valoraciones potenciales el escenario teórico en el que no se ha desplegado ninguna salvaguarda y valoraciones residuales el escenario realista una vez incorporadas las salvaguardas. De ahí surgen los conceptos de impacto y riesgo potencial frente a impacto y riesgo residual, este último clave para decidir si el nivel alcanzado es aceptable.

En el Libro I estos pasos se formalizan en tareas concretas con productos de entrada y salida definidos, tal como muestra la Tabla 3.

Tabla 3. Tareas del Método de Análisis de Riesgos (MAR)

Tarea	Denominación	Propósito
MAR.1	Caracterización de los activos	Identificar activos, sus dependencias y valorarlos en cada dimensión de seguridad.
MAR.2	Caracterización de las amenazas	Identificar las amenazas relevantes y estimar su frecuencia y su degradación sobre los activos.
MAR.3	Caracterización de las salvaguardas	Identificar las salvaguardas existentes y valorar su eficacia frente a las amenazas.
MAR.4	Estimación del estado de riesgo	Calcular el impacto y el riesgo, tanto potencial como residual, para cada activo.

Nota. Elaboración propia a partir de Ministerio de Hacienda y Administraciones Públicas (2012a).

Concluido el análisis, MAGERIT aborda la gestión o tratamiento de riesgos, cuya finalidad es decidir qué hacer con el riesgo residual estimado. Las opciones básicas de tratamiento son cuatro: aceptar el riesgo cuando su nivel es asumible; mitigarlo o reducirlo mediante nuevas salvaguardas; transferirlo o compartirlo, por ejemplo, mediante contratación de seguros o externalización; y evitarlo o eliminarlo suprimiendo el activo o la actividad que lo origina. La dirección de la organización es quien acepta formalmente el riesgo residual o solicita salvaguardas adicionales.

MAGERIT también formaliza el desarrollo de un Proyecto de Análisis de Riesgos, que aplica el método en un contexto concreto y se organiza en tres fases: PAR.1, Actividades preliminares, correspondiente a la definición de objetivos, alcance, roles y planificación del proyecto; PAR.2, Elaboración del análisis de riesgos, correspondiente a la ejecución de las tareas MAR sobre el sistema seleccionado; y PAR.3, Comunicación de resultados, correspondiente a la documentación y presentación de conclusiones a los responsables para la toma de decisiones.

Aplicación Práctica del Modelo

En la práctica, la aplicación de MAGERIT suele apoyarse en la herramienta PILAR (Procedimiento Informático-Lógico para el Análisis de Riesgos), desarrollada por el Centro Criptológico Nacional. PILAR implementa el método, automatiza el cálculo del impacto y el riesgo acumulado, repercutido, potencial y residual sobre las cinco dimensiones de seguridad, y facilita la elaboración de los informes del proyecto (Centro Criptológico Nacional, s. f.).

Para ilustrar el flujo de trabajo, considérese un ejemplo sencillo: el servidor de base de datos de clientes de una pequeña empresa. En la caracterización del activo (MAR.1), el servidor [HW] y la base de datos de clientes [D] se identifican como activos esenciales, valorados alto en confidencialidad, integridad y disponibilidad por contener datos personales de los que dependen los servicios de la empresa. En la caracterización de amenazas (MAR.2) se identifican el acceso no autorizado o el cifrado malicioso por ransomware [A], el fallo del suministro eléctrico [I] y el incendio de las instalaciones [N], estimando la frecuencia de cada una y la degradación que provocaría. En la caracterización de salvaguardas (MAR.3) se evalúan medidas ya existentes o previstas, como el control de acceso y el cifrado de la base de datos, las copias de respaldo periódicas y el sistema de alimentación ininterrumpida. Finalmente, en la estimación del estado de riesgo (MAR.4) se calcula el riesgo potencial, sin salvaguardas, y el riesgo residual, con ellas; si el riesgo residual del ransomware sigue siendo elevado, la dirección puede decidir mitigarlo con nuevas salvaguardas o aceptarlo formalmente.

El resultado típico de un proyecto de este tipo es un conjunto de entregables que incluyen la matriz de riesgos, un mapa de calor por activo, un plan de tratamiento priorizado y la declaración formal de aceptación del riesgo residual. Gracias a su alineación con ISO/IEC 27005 e ISO 31000, estos resultados pueden integrarse en un Sistema de Gestión de Seguridad de la Información y sirven de evidencia para el cumplimiento del Esquema Nacional de Seguridad (Organización Internacional de Normalización, 2022).

En síntesis, el estudio de MAGERIT permite reconocer sus principales fortalezas: es una metodología pública, gratuita, detallada y de aplicación paso a paso, que se apoya en un catálogo normalizado de activos, amenazas y salvaguardas y en una herramienta de cálculo. Su enfoque cuantitativo-cualitativo y su alineación con las normas ISO facilitan la trazabilidad de las decisiones de seguridad. Como contrapartida, un análisis completo puede requerir un esfuerzo considerable en organizaciones medianas o grandes, lo que exige planificación y compromiso de la dirección.

Modelo OCTAVE Allegro: Enfoque Organizacional y Priorización de Activos

El modelo OCTAVE es una metodología estructurada para la evaluación de riesgos de seguridad de la información y la planificación estratégica. Fue desarrollada por el CERT (Computer Emergency Response Team) del Software Engineering Institute (SEI) en la Universidad Carnegie Mellon. A diferencia de las evaluaciones de riesgo puramente tecnológicas, OCTAVE se centra en el riesgo organizacional y los aspectos estratégicos. Dentro de esta familia, OCTAVE Allegro es la versión más moderna y optimizada, diseñada para ser ágil, menos intensiva en recursos y centrada directamente en la información.

Definiciones Principales

Para entender OCTAVE Allegro es fundamental dominar su vocabulario específico. El Activo de Información es el foco central del modelo: se refiere a los datos o información, en formato digital o físico, que tienen valor para la organización y requieren protección. El Contenedor de Información es el lugar físico, técnico o humano donde un activo de información se almacena, transporta o procesa, por ejemplo, un servidor de base de datos, un archivero físico o un empleado clave. El Área de Preocupación es una condición o situación del mundo real que podría afectar negativamente a un activo de información si llegara a ocurrir. El Escenario de Amenaza es una descripción detallada de cómo una amenaza podría materializarse contra un activo de información, identificando el actor, el motivo, el

acceso y el resultado. Los Requerimientos de Seguridad son las necesidades específicas de un activo en términos de Confidencialidad, Integridad y Disponibilidad, la tríada CIA.

OCTAVE original podía resultar abrumador porque requería analizar toda la infraestructura de TI de la organización. OCTAVE Allegro simplifica esto al cambiar el paradigma: en lugar de evaluar la infraestructura para ver qué información contiene, evalúa la información y luego rastrea en qué infraestructura reside.

Enfoque Organizacional

Allegro obliga a la organización a mirar la seguridad de la información a través del lente de los objetivos del negocio. No se trata de «proteger servidores», sino de «proteger la capacidad de la organización para operar». El modelo asume que el personal de negocio los dueños de los procesos son quien mejor entiende el valor de la información, no necesariamente el departamento de TI. Por ello, Allegro está diseñado para ser ejecutado mediante talleres colaborativos donde el negocio y TI trabajan juntos.

Priorización de Activos

La priorización en Allegro no se basa en el costo del hardware que almacena los datos, sino en el impacto cualitativo que tendría la pérdida o exposición de esos datos. Esta priorización se logra mediante la creación de Criterios de Medición de Riesgos, en los que la organización define umbrales de impacto en áreas clave como la salud y seguridad humana, el impacto financiero, la reputación y confianza de los clientes, y el cumplimiento legal y normativo. Al evaluar un activo contra estos criterios, los activos críticos aquellos cuya vulneración causaría un impacto severo en múltiples áreas suben naturalmente a la cima de la lista de prioridades, dictando dónde deben invertirse los recursos de seguridad.

Proceso: las Cuatro Fases y Ocho Pasos de Allegro

El modelo se ejecuta de manera secuencial a través de un proceso altamente estructurado, sintetizado en la Tabla 4.

Tabla 4. Fases y pasos del proceso OCTAVE Allegro

Fase	Paso	Descripción del proceso
1. Establecer criterios	1. Desarrollar criterios de medición de riesgos	Se definen las escalas cualitativas (alto, medio, bajo) para medir el impacto organizacional si un riesgo se materializa.
2. Perfil de activos	2. Desarrollar el perfil del activo	Se identifica y documenta el activo de información, asignándole un dueño y definiendo sus requerimientos de seguridad (CIA).
2. Perfil de activos	3. Identificar contenedores	Se mapea exhaustivamente dónde reside el activo: sistemas de TI, ubicaciones físicas, personal interno o proveedores externos.
3. Identificar amenazas	4. Identificar áreas de preocupación	Se genera una lista de posibles eventos adversos que podrían comprometer los contenedores del activo.
3. Identificar amenazas	5. Desarrollar escenarios de amenaza	Se formalizan las áreas de preocupación en perfiles de amenaza estructurados (actor, medio, motivo, resultado).
4. Mitigar riesgos	6. Identificar riesgos	Se evalúa cómo cada escenario de amenaza afectaría al activo y qué consecuencias traería.
4. Mitigar riesgos	7. Analizar riesgos	Se utiliza la matriz de criterios del Paso 1 para calcular una puntuación de riesgo global para cada escenario.
4. Mitigar riesgos	8. Seleccionar mitigación	La gerencia decide la estrategia: aceptar el riesgo, diferir (postergar la acción) o mitigar (implementar controles de seguridad).

Nota. Elaboración propia con base en Caralli et al. (2007).

Desempeño General y Casos de Uso

En la práctica, OCTAVE Allegro se desempeña de manera sobresaliente en organizaciones que necesitan establecer un gobierno de seguridad basado en riesgos sin invertir meses en auditorías técnicas. Entre sus ventajas clave destacan la agilidad, pues al enfocarse solo en contenedores críticos reduce drásticamente el tiempo de análisis en comparación con metodologías centradas en la red; la nula dependencia de herramientas técnicas, ya que no requiere escaneos de vulnerabilidades ni pruebas de penetración en sus fases iniciales, siendo un enfoque puramente analítico y estratégico; y el uso de un lenguaje de negocio, que traduce los problemas técnicos por ejemplo, la falta de un parche en un servidor SQL a un lenguaje de impacto empresarial, como la posible exposición de datos de clientes que violaría leyes de privacidad.

En síntesis, OCTAVE Allegro aporta al proyecto un enfoque complementario al de MAGERIT: mientras este último ofrece un catálogo exhaustivo y normalizado, Allegro ofrece agilidad y un anclaje directo a los objetivos de negocio, lo cual resulta especialmente valioso para una micro o pequeña empresa que no dispone de una estructura organizacional compleja ni de personal técnico dedicado a la seguridad.

Estudio de Conceptos Clave: Activos, Amenazas, Vulnerabilidades y Brechas

Una vez examinados de forma individual los modelos MAGERIT y OCTAVE Allegro, esta sección profundiza en los conceptos fundamentales que ambos comparten y que constituyen el lenguaje común de la gestión de riesgos: los activos informáticos, su clasificación y criticidad, y las amenazas y vulnerabilidades también llamadas brechas que los afectan.

Fundamentos de Gestión de Riesgos en Seguridad Informática

La gestión de riesgos de seguridad de la información es el proceso mediante el cual una organización identifica, analiza y trata sistemáticamente los riesgos que

amenazan la confidencialidad, integridad y disponibilidad de sus activos de información. Su fundamento conceptual proviene de la norma ISO 31000, que define el «Marco de Gestión de Riesgos» dentro del cual se ejecuta el «Proceso de Gestión de Riesgos», y se complementa con la norma ISO/IEC 27005, específica para la gestión de riesgos de seguridad de la información (Organización Internacional de Normalización, 2018; International Organization for Standardization, 2018).

El proceso general, común a MAGERIT y a OCTAVE Allegro aunque con énfasis distintos, comprende cuatro grandes momentos: la identificación de los activos y su valoración; la identificación de las amenazas y vulnerabilidades que los afectan; la estimación del impacto y del riesgo que resultaría de la materialización de esas amenazas; y la decisión sobre el tratamiento del riesgo, ya sea aceptándolo, mitigándolo, transfiriéndolo o evitándolo. Ninguno de estos momentos puede omitirse sin comprometer la validez de los siguientes, porque cada uno constituye el insumo del que le sigue.

Para una micro o pequeña empresa, organización de referencia adoptada en todo el trabajo, la gestión de riesgos no es un ejercicio meramente documental sino una herramienta de supervivencia: permite concentrar recursos limitados en los activos y controles de mayor rendimiento, en lugar de distribuirlos de manera uniforme e ineficiente sobre todo el inventario tecnológico.

Identificación y Clasificación de Activos Informáticos

Concepto de Activo

Se entiende por activo todo componente o funcionalidad de un sistema de información susceptible de ser atacado, deliberada o accidentalmente, con consecuencias para la organización. Esta definición amplia incluye información, datos, servicios, aplicaciones informáticas, equipos, redes de comunicaciones, soportes de información, instalaciones y personas.

Un principio central en la valoración de activos es que no se está hablando de lo que cuestan las cosas, sino de lo que valen: si un activo puede prescindirse sin consecuencias, no requiere protección; si su ausencia o daño genera un perjuicio, entonces es necesario determinar qué tan grande es ese perjuicio, pues eso es precisamente lo que se debe proteger.

El valor de un activo puede ser propio o acumulado. Los activos inferiores en un esquema de dependencias acumulan el valor de los activos que se apoyan en ellos; por ejemplo, un servidor de base de datos hereda parte del valor crítico de la información que almacena. El valor nuclear suele residir en la información que el sistema maneja y en los servicios que presta, denominados activos esenciales, mientras que el resto de los activos queda subordinado a las necesidades de explotación y protección de estos elementos esenciales.

Metodología de Identificación

El proceso de identificación de activos debe responder a la pregunta «¿qué tiene la organización que sea necesario proteger?». Esta tarea es crítica porque una identificación deficiente compromete todo el análisis posterior. Una buena identificación es importante desde varios puntos de vista: materializa con precisión el alcance del proyecto, permite que los distintos grupos de usuarios hablen un lenguaje común sobre los activos, y posibilita determinar con exactitud las dependencias entre ellos.

El método de análisis de riesgos de MAGERIT organiza esta fase en tres subtarefas secuenciales: la identificación de los activos propiamente dicha, el establecimiento de las dependencias entre activos, y su valoración, es decir, determinar qué parte del valor total del sistema se soporta en cada uno de ellos. Por su parte, OCTAVE inicia con el establecimiento de criterios de medición del riesgo alineados con la misión, los objetivos y los factores críticos de éxito de la organización, para luego enfocar la identificación específicamente en los activos de información, elaborando un perfil que delimita claramente cada activo, identifica sus

necesidades de seguridad y describe todos los contenedores tecnológicos, físicos o humanos donde dicho activo reside, se transporta o se procesa.

Taxonomía según MAGERIT

MAGERIT distingue conceptualmente entre activos esenciales y activos de soporte. Los primeros información y servicios son los que dan sentido a la existencia del sistema y determinan los requisitos de seguridad para todos los demás componentes. Los segundos sostienen operativamente a los esenciales: aplicaciones, equipos, redes, soportes de almacenamiento, instalaciones y personal. La Tabla 5 resume la clasificación jerárquica propuesta por el Catálogo de Elementos de MAGERIT v3, adaptada a un contexto empresarial típico de una micro o pequeña empresa.

Tabla 5. Clasificación de activos según MAGERIT

Categoría	Tipo de activo (MAGERIT)	Ejemplos
Esenciales	Información y servicios	Bases de datos de clientes, expedientes, servicio de facturación en línea
Soporte	Aplicaciones (software)	ERP, sistema contable, navegador, sistema operativo
Soporte	Equipos informáticos (hardware)	Servidores, estaciones de trabajo, dispositivos móviles
Soporte	Comunicaciones	Red LAN, enlaces WAN, routers, firewalls, VPN
Soporte	Soportes de información	Discos, cintas de respaldo, memorias USB, medios ópticos
Entorno	Equipamiento auxiliar	UPS, aire acondicionado, sistemas contra incendios
Entorno	Instalaciones	Centro de datos, oficinas, cuartos de telecomunicaciones
Entorno	Personal	Administradores de sistemas, usuarios internos, proveedores

Nota. Elaboración propia con base en el Catálogo de Elementos de MAGERIT v3.

Clasificación según OCTAVE Allegro

OCTAVE Allegro simplifica la clasificación centrándose exclusivamente en los activos de información, entendidos como el conocimiento o los datos que tienen valor para la organización. A diferencia de MAGERIT, que clasifica una amplia variedad de tipos de activos, OCTAVE Allegro considera que la tecnología, el personal y las instalaciones son «contenedores» en los que reside, se transporta o se procesa el activo de información, y no activos en sí mismos.

Este enfoque práctico está organizado en cuatro fases: en la primera se definen los criterios organizacionales de medición del riesgo; en la segunda se elabora el perfil de los activos críticos de información, asignando un custodio responsable y estableciendo los requisitos de confidencialidad, integridad y disponibilidad; en la tercera se identifican las amenazas propias de cada contenedor; y en la cuarta se identifican y analizan los riesgos, dando inicio a los planes de mitigación.

La combinación de ambos enfoques resulta especialmente útil para una micro o pequeña empresa: la taxonomía detallada de MAGERIT ayuda a construir un inventario exhaustivo, mientras que el enfoque simplificado de OCTAVE Allegro facilita priorizar rápidamente los activos de información realmente críticos sin requerir una estructura organizacional compleja.

Criticidad de los Activos: Valor, Impacto en el Negocio y Confidencialidad

Una vez identificados y clasificados los activos, el siguiente paso y el de mayor relevancia para este trabajo es determinar su criticidad. La criticidad de un activo es una medida compuesta que resulta de combinar tres elementos: el valor que dicho activo representa para la organización, el impacto que su pérdida, alteración o divulgación tendría sobre el negocio, y el nivel de confidencialidad que requiere la información que contiene o procesa.

Valor del Activo

El valor de un activo no se mide en términos monetarios o contables, sino en términos de la necesidad de protegerlo: cuanto más valioso es un activo, mayor nivel de protección requerirá en las dimensiones de seguridad que le sean pertinentes. Para homogeneizar esta estimación, que tiene un fuerte componente de juicio experto, MAGERIT propone una escala de valoración que va de 0, despreciable, a 10, extremo, permitiendo comparar activos de naturaleza muy distinta bajo un mismo criterio, como se muestra en la Tabla 6.

Tabla 6. Escala de valoración de activos

Valor	Criterio	Descripción del daño
10	Extremo	Daño extremadamente grave; pone en riesgo la continuidad de la organización
9	Muy alto	Daño muy grave, con repercusiones legales y reputacionales severas
6 – 8	Alto	Daño grave, afecta de forma significativa la operación del negocio
3 – 5	Medio	Daño importante, requiere atención y recursos de recuperación
1 – 2	Bajo	Daño menor, impacto limitado y de fácil recuperación
0	Despreciable	Irrelevante a efectos prácticos

Nota. Elaboración propia con base en el Catálogo de Elementos de MAGERIT v3.

Dimensiones de Valoración

MAGERIT establece que un activo debe valorarse en varias dimensiones de seguridad, ya que un mismo activo puede ser muy crítico en una dimensión y poco crítico en otra. Por ejemplo, un sitio web corporativo informativo puede requerir alta disponibilidad, pero baja confidencialidad, mientras que un expediente médico requiere alta confidencialidad, aunque su indisponibilidad temporal sea tolerable. La Tabla 7 presenta la pregunta orientadora de cada dimensión.

Tabla 7. Dimensiones de valoración de activos

Dimensión	Pregunta orientadora
Confidencialidad	¿Qué daño causaría que el activo fuera conocido por quien no está autorizado?
Integridad	¿Qué perjuicio causaría que el activo estuviera dañado o alterado?
Disponibilidad	¿Qué perjuicio causaría no tener el activo disponible cuando se necesita?
Autenticidad	¿Qué perjuicio causaría no saber con certeza quién origina el activo o la acción?
Trazabilidad	¿Qué perjuicio causaría no poder rastrear quién hizo qué y cuándo sobre el activo?

Nota. Dimensiones de valoración de activos según MAGERIT v3.

Impacto en el Negocio

El impacto en el negocio es la consecuencia que la materialización de una amenaza tendría sobre la operación, la reputación, el cumplimiento legal o la situación financiera de la organización. Este análisis, conocido en otros marcos como Business Impact Analysis, obliga a preguntarse qué ocurriría si un activo determinado dejara de estar disponible, fuera alterado sin autorización o llegara a manos de terceros no autorizados.

Para una micro o pequeña empresa, el impacto en el negocio suele manifestarse en dimensiones muy concretas: pérdida de ventas por interrupción del servicio, costos de recuperación de información, sanciones por incumplimiento de normativa de protección de datos, pérdida de confianza de los clientes y, en los casos más graves, la inviabilidad de continuar operando. OCTAVE Allegro formaliza este análisis mediante la definición previa de áreas de impacto por ejemplo, reputación, financiera, productividad, seguridad y legal a las que se asigna una prioridad relativa antes de evaluar cualquier activo, de modo que la valoración del impacto sea consistente en toda la organización.

El nivel de riesgo intrínseco de un activo puede entenderse, de forma simplificada, como la combinación del impacto potencial de una amenaza con la

frecuencia o probabilidad de que dicha amenaza se materialice; a mayor impacto y mayor probabilidad, mayor es la prioridad de protección que debe asignarse al activo.

Confidencialidad como Criterio Crítico

De las dimensiones de valoración, la confidencialidad merece un análisis particular porque suele ser el criterio que con mayor frecuencia determina la criticidad de los activos de información en una micro o pequeña empresa. La confidencialidad responde a la pregunta: ¿qué daño causaría que este activo fuera conocido por quien no debe conocerlo?

Esta valoración es especialmente relevante para activos que contienen datos personales de clientes o empleados, información financiera, credenciales de acceso, contratos, propiedad intelectual o estrategias comerciales. La pérdida de confidencialidad no solo genera un daño reputacional inmediato, sino que, en muchos países incluyendo el marco normativo guatemalteco en materia de protección de datos y frente a las obligaciones contractuales con terceros, puede derivar en responsabilidades legales y contractuales para la organización.

Un criterio práctico para asignar el nivel de confidencialidad de un activo consiste en clasificar la información que contiene en al menos tres niveles: información pública, cuya divulgación no genera daño; información interna o de uso restringido, cuya divulgación afecta la operación o la imagen de la organización; e información confidencial o reservada, cuya divulgación puede generar daños graves, sanciones legales o pérdida de la confianza de clientes y socios.

Determinación de la Criticidad

La criticidad final de un activo se obtiene al combinar su valor para el negocio con el nivel de confidencialidad y las demás dimensiones de seguridad aplicables. En la práctica, esto se traduce en una matriz o tabla que permite priorizar los activos, orientando la asignación de recursos de seguridad hacia aquellos elementos cuya

pérdida, alteración o divulgación tendría el mayor efecto negativo sobre la organización. La Tabla 8 presenta un ejemplo aplicado a activos típicos de una micro o pequeña empresa.

Tabla 8. Ejemplo de determinación de criticidad

Activo	Valor para el negocio	Confidencialidad	Criticidad resultante
Base de datos de clientes	Alto	Alta (datos personales)	Crítica
Servidor de correo interno	Medio	Media	Importante
Sitio web informativo	Bajo	Baja (información pública)	No crítica
Sistema de facturación electrónica	Alto	Alta (datos financieros)	Crítica

Nota. Ejemplo de determinación de criticidad combinando valor de negocio y confidencialidad (elaboración propia).

Como se observa en la tabla anterior, no todos los activos que soportan un sistema de información tienen la misma criticidad. Identificar correctamente cuáles son los activos críticos permite a la organización concentrar sus esfuerzos de protección controles de acceso, cifrado, respaldos, monitoreo en aquellos elementos donde el riesgo es más alto, en lugar de distribuir recursos limitados de manera uniforme e ineficiente sobre todo el inventario.

Amenazas, Vulnerabilidades, Brechas y Criticidad

El presente apartado profundiza en los conceptos de amenaza y vulnerabilidad con especial atención a la distinción entre su origen interno y externo. Esa distinción no es un simple criterio de ordenamiento: determina qué controles resultan eficaces, dado que un mismo activo requiere defensas de naturaleza distinta según si el actor que lo amenaza ya posee acceso legítimo o debe obtenerlo.

Concepto de Amenaza

MAGERIT define la amenaza como todo evento capaz de desencadenar un incidente en la organización, produciendo daños materiales o pérdidas inmateriales en sus activos. Dos rasgos de esta definición merecen subrayarse. El primero es que la amenaza es un evento y no una debilidad: existe con independencia de que la organización esté o no preparada para resistirla. El segundo es que su origen no es necesariamente humano ni deliberado; un corte prolongado del suministro eléctrico y un empleado que borra un archivo por descuido son amenazas tan legítimas como un ataque de ransomware.

De ello se desprende una consecuencia práctica de la mayor importancia: las amenazas no se eliminan. Ninguna organización puede suprimir la existencia de los delincuentes informáticos, de los errores humanos o de los fenómenos naturales. Lo que puede gestionarse es la probabilidad de que la amenaza alcance al activo y la magnitud del daño que produzca si lo alcanza. Toda la actividad de tratamiento del riesgo opera sobre esos dos factores, nunca sobre la amenaza en sí.

Al actuar sobre un activo, la amenaza degrada una o varias de las cinco dimensiones de seguridad: confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad. Identificar cuál dimensión se ve comprometida no es un formalismo, pues de ello depende la elección del control: una amenaza que degrada la disponibilidad exige redundancia y respaldos, mientras que una que degrada la confidencialidad exige cifrado y control de acceso. La misma amenaza puede además afectar dimensiones distintas en activos distintos, lo que obliga a evaluarla siempre en relación con un activo concreto y no de forma abstracta.

Concepto de Vulnerabilidad

La vulnerabilidad es la debilidad, la deficiencia o la ausencia de control que permite que una amenaza llegue a producir daño. En la terminología del proyecto se le denomina también brecha. A diferencia de la amenaza, la vulnerabilidad no es un evento sino un estado, y su rasgo característico es que por sí sola no causa

perjuicio alguno: un servidor sin actualizar no produce daño mientras nadie explote la falla que arrastra, y un empleado sin formación en seguridad no compromete nada mientras no reciba un mensaje fraudulento.

Esta condición de estado tiene una implicación favorable para la organización: a diferencia de las amenazas, las vulnerabilidades sí pueden eliminarse, o al menos reducirse de manera deliberada, porque residen dentro del ámbito de control de la propia entidad. Es precisamente ahí donde la gestión de la seguridad concentra su capacidad de acción. Conviene además no confundir la vulnerabilidad con el riesgo: la primera es una carencia observable y verificable mediante auditoría o análisis técnico, mientras que el segundo es una estimación de daño probable que combina esa carencia con la amenaza que la aprovecha y con el valor del activo expuesto.

Relación entre Amenaza, Vulnerabilidad y Riesgo

Los tres elementos se combinan de forma multiplicativa y no aditiva. El riesgo aparece únicamente cuando concurren simultáneamente un activo de valor, una amenaza capaz de dañarlo y una vulnerabilidad que le permita alcanzarlo; si cualquiera de los tres factores tiende a cero, el riesgo resultante tiende también a cero, con independencia de la magnitud de los otros dos.

De esa estructura se derivan tres conclusiones que orientan todo el trabajo posterior. La primera es que una amenaza sin vulnerabilidad correspondiente no genera riesgo apreciable: una campaña de suplantación de identidad pierde casi toda su eficacia frente a un segundo factor de autenticación resistente al engaño. La segunda es que una vulnerabilidad sobre un activo de valor despreciable tampoco genera riesgo apreciable, lo que justifica no invertir recursos de forma uniforme sobre todo el inventario. La tercera, y la más útil en la práctica, es que la relación entre amenazas y vulnerabilidades no es de uno a uno: una sola vulnerabilidad puede habilitar varias amenazas distintas, y una misma amenaza puede aprovechar varias vulnerabilidades alternativas. Identificar las

vulnerabilidades transversales aquellas que habilitan el mayor número de amenazas es la vía más eficiente para reducir el riesgo agregado con un número reducido de controles.

Metodología de Identificación

MAGERIT aborda la identificación de forma descendente y sistemática. Partiendo del inventario de activos ya elaborado, para cada uno se determina qué amenazas del catálogo del Libro II le resultan aplicables según su tipo, y a continuación se estima la degradación que cada amenaza produciría en las dimensiones pertinentes y la probabilidad de que llegue a materializarse. El resultado es exhaustivo y trazable, cualidad valiosa ante una auditoría, aunque exige un esfuerzo considerable cuando el inventario es extenso.

OCTAVE Allegro procede de manera ascendente y más económica. En lugar de recorrer un catálogo completo, parte de las áreas de preocupación es decir, de las situaciones que los responsables de la organización identifican como preocupantes en función de su experiencia y las desarrolla en escenarios de amenaza estructurados. Cada escenario se construye sobre un activo de información y sobre los contenedores tecnológicos, físicos y humanos donde ese activo reside, se transporta o se procesa, lo que dirige la identificación hacia donde la información efectivamente circula.

Para una micro o pequeña empresa la combinación resulta especialmente conveniente: el catálogo de MAGERIT aporta un marco de referencia que evita omitir categorías completas de amenaza, mientras que el enfoque por escenarios de OCTAVE Allegro permite avanzar sin necesidad de una estructura organizacional compleja ni de un inventario exhaustivo previo. A ambos conviene sumar fuentes externas de identificación que ninguna de las dos metodologías provee por sí sola: los registros de incidentes propios, las bases públicas de vulnerabilidades conocidas, los catálogos de debilidades de aplicaciones web y las matrices de

técnicas de ataque documentadas permiten contrastar el juicio interno con lo que efectivamente está ocurriendo en el entorno.

Clasificación de las Amenazas

Taxonomía según MAGERIT

El Catálogo de Elementos de MAGERIT v3 organiza las amenazas en cuatro bloques identificados por una letra. Los dos primeros agrupan amenazas del entorno, ajenas a la voluntad de las personas de la organización; los dos últimos agrupan amenazas de origen humano y se distinguen entre sí, de manera decisiva, por la presencia o ausencia de intención. Esa separación entre el error y el ataque deliberado es la que permite después asignar controles diferenciados, ya que el error se combate con diseño y formación mientras que el ataque se combate con restricción y vigilancia, como se resume en la Tabla 9.

Tabla 9. Taxonomía de amenazas según MAGERIT v3

Bloque	Naturaleza	Ejemplos representativos	Origen predominante
[N] Desastres naturales	Sucesos que ocurren sin intervención humana alguna	Fuego, daños por agua, terremoto, inundación, tormenta eléctrica	Externo (entorno)
[I] De origen industrial	Fallos de los servicios y sistemas de soporte de los que depende la operación	Corte del suministro eléctrico, condiciones inadecuadas de temperatura o humedad, fallo de telecomunicaciones	Externo o mixto
[E] Errores y fallos no intencionados	Acciones humanas sin voluntad de causar daño	Errores de usuarios y del administrador, errores de configuración, fugas de información, vulnerabilidades de programas	Interno
[A] Ataques intencionados	Acciones deliberadas de personas con	Suplantación de identidad, abuso de privilegios, acceso no autorizado, denegación de	Interno o externo

Bloque	Naturaleza	Ejemplos representativos	Origen predominante
	voluntad de dañar o de obtener un beneficio	servicio, ingeniería social, extorsión	

Nota. Elaboración propia con base en el Catálogo de Elementos de MAGERIT v3.

La tabla evidencia un hecho que conviene retener: el bloque de errores no intencionados es, en su totalidad, de origen interno, y el bloque de ataques deliberados admite ambos orígenes. Dicho de otro modo, la organización no puede atribuir al exterior la mayor parte de las categorías de amenaza que la afectan. Esta observación resulta particularmente pertinente en una micro o pequeña empresa, donde la percepción del riesgo suele concentrarse en el atacante externo mientras las amenazas de los bloques [E] e [I] quedan desatendidas por resultar menos visibles.

Enfoque de OCTAVE Allegro

OCTAVE Allegro no propone un catálogo cerrado de amenazas sino una estructura para describirlas. Puesto que esta metodología considera que la tecnología, las personas y las instalaciones son contenedores en los que reside el activo de información y no activos en sí mismos, la amenaza se formula siempre como un escenario que recorre un contenedor determinado. Cada escenario se descompone en un conjunto fijo de componentes, lo que aporta una ventaja frente al catálogo: obliga a explicitar quién actúa, con qué medio y con qué resultado, evitando enunciados vagos como «riesgo de fuga de información» que no permiten derivar ningún control concreto, tal como sintetiza la Tabla 10.

Tabla 10. Componentes del perfil de amenaza en OCTAVE Allegro

Componente	Pregunta que responde	Ejemplo aplicado a una micro o pequeña empresa
Activo de información	¿Qué es lo que se quiere proteger?	Base de datos de clientes con datos personales y de facturación
Contenedor	¿Dónde reside, se transporta o se procesa ese activo?	Servidor de la oficina, respaldo en un servicio en la nube, computadora del contador (contenedor humano)
Actor	¿Quién origina la amenaza?	Empleado del área administrativa con acceso al sistema; atacante externo que envía correo fraudulento
Medio	¿Cómo se materializa la acción?	Copia de la base a una memoria USB; mensaje de suplantación con enlace a un sitio falso
Motivo	¿La acción es deliberada o accidental?	Deliberado, por beneficio económico; o accidental, por desconocimiento del procedimiento
Resultado	¿Qué le ocurre al activo de información?	Divulgación, modificación, destrucción o interrupción del acceso
Requisito de seguridad afectado	¿Cuál de las necesidades de seguridad del activo se incumple?	Confidencialidad de los datos personales de los clientes

Nota. Elaboración propia con base en Caralli et al. (2007).

La utilidad de esta estructura para el análisis del origen de la amenaza es directa: el componente «actor» resuelve por sí mismo la clasificación entre interno y externo, y el componente «contenedor» revela por dónde el actor externo necesita pasar para alcanzar el activo.

Amenazas de Origen Interno

Las amenazas internas provienen de personas que poseen acceso legítimo a los sistemas de la organización: empleados en activo, contratistas, proveedores con conexión establecida y personal recién desvinculado cuyos accesos no han sido

revocados. Su rasgo distintivo, y la razón de su gravedad, es que no necesitan vencer el perímetro porque ya se encuentran dentro, y sus acciones se ejecutan dentro del ámbito de lo que sus credenciales autorizan, de modo que los controles diseñados para detectar intrusiones no las registran como anomalía.

Perfiles del Actor Interno

Agrupar todas las amenazas internas bajo la idea del empleado desleal conduce a controles equivocados, porque el perfil más frecuente no actúa con intención de dañar. La literatura de seguridad distingue tres figuras que exigen tratamientos distintos, presentadas en la Tabla 11.

Tabla 11. Perfiles del actor de amenaza interna

Perfil	Intención	Manifestación típica	Control predominante
Interno malicioso	Deliberada: beneficio propio, agravio laboral o traslado de información a un competidor	Extracción de la base de clientes antes de renunciar, sabotaje ante un despido previsto, fraude en la facturación	Preventivo: segregación de funciones y mínimo privilegio, con trazabilidad no manipulable como respaldo detectivo
Interno negligente	Ninguna: no existe voluntad de causar daño	Reutilización de contraseñas, envío de información al destinatario equivocado, copia de datos a un servicio personal en la nube, extravío de un equipo	Preventivo por diseño: barreras técnicas que impidan el error, más formación con medición de su eficacia
Interno comprometido	Ninguna: la persona no actúa, es utilizada	Credencial obtenida mediante suplantación o robo de sesión, equipo infectado desde el cual el atacante externo opera con una identidad legítima	Autenticación resistente a la suplantación, endurecimiento del equipo y detección de comportamiento anómalo

Nota. Elaboración propia.

El interno negligente es, con diferencia, el perfil más frecuente, y de ello se deriva la orientación práctica más importante de este apartado: la respuesta a la mayoría de las amenazas internas no es disciplinaria sino de diseño. Sancionar a quien se equivoca no reduce la probabilidad de que el error vuelva a producirse si las condiciones que lo hicieron posible permanecen intactas. El interno comprometido, por su parte, difumina la frontera entre lo interno y lo externo, y es la figura que obliga a tratar esa dicotomía con cautela.

Trasladadas al catálogo de MAGERIT, las amenazas internas de mayor recurrencia son los errores de los usuarios y del administrador, los errores de configuración, la alteración accidental de la información, las fugas de información, la indisponibilidad del personal y, en el bloque deliberado, el abuso de privilegios, el acceso no autorizado, la modificación o divulgación intencionada de información y la suplantación de identidad de otro usuario interno. En una micro o pequeña empresa suelen manifestarse de forma concreta en la copia de información a dispositivos personales, el uso de servicios en la nube no aprobados, la ejecución de operaciones sin autorización previa y la permanencia de accesos activos tras la salida de un empleado.

Merece mención aparte una amenaza interna de naturaleza organizativa y no individual: la deficiencia estructural, catalogada por MAGERIT como parte del bloque de errores. La ausencia de un plan de sucesión, la inexistencia de un proceso formal de baja de personal, la falta de segregación de funciones o la carencia de un programa de formación no son actos atribuibles a una persona, sino omisiones de la organización que elevan la probabilidad de todas las demás amenazas simultáneamente. Por esa razón su corrección produce un efecto de reducción del riesgo desproporcionadamente amplio en relación con su costo.

Una organización pequeña presenta condiciones estructurales que intensifican este tipo de amenaza. La primera y más determinante es la acumulación de funciones: cuando pocas personas cubren todos los procesos, la segregación de funciones se vuelve materialmente imposible, y quien puede ejecutar una operación

es también quien la aprueba y, con frecuencia, quien custodia su registro. En ese contexto el control detectivo pierde validez, porque el mismo actor que podría cometer un acto irregular está en posición de ocultarlo. La respuesta viable no es una separación de funciones que la estructura no admite, sino la supervisión por parte de la dirección y la conservación de registros fuera del alcance de quien opera el sistema. A ello se suman otros factores frecuentes: la confianza personal como sustituto del control formal, la ausencia de acuerdos de confidencialidad con vigencia posterior a la terminación del contrato, el uso de equipo propio del empleado sin gestión por parte de la empresa, la modalidad de teletrabajo sin controles equivalentes a los de la oficina y la elevada rotación en los perfiles técnicos.

Amenazas de Origen Externo

Las amenazas externas provienen de actores que no cuentan con acceso autorizado y que buscan obtenerlo. Sus perfiles son diversos: grupos de delincuencia organizada que operan con motivación económica y a escala industrial, actores oportunistas que emplean herramientas automatizadas contra cualquier objetivo alcanzable, competidores interesados en información comercial, activistas con motivación ideológica y, cada vez con mayor frecuencia, proveedores o socios comprometidos que se convierten en vía de entrada sin saberlo. Una micro o pequeña empresa rara vez es un objetivo elegido de manera individual; suele ser alcanzada por barridos automatizados o como paso intermedio hacia un cliente de mayor tamaño, circunstancia que desmiente la creencia de que un tamaño reducido constituye por sí mismo una protección.

La Tabla 12 resume las amenazas externas de mayor frecuencia y su vector de entrada habitual.

Tabla 12. Amenazas de origen externo más frecuentes

Amenaza	Código MAGERIT	Vector de entrada habitual	Dimensiones comprometidas
Ingeniería social y suplantación dirigida	[A.30], [A.5]	Correo electrónico, mensajería instantánea o llamada telefónica dirigida a una persona concreta	Confidencialidad, integridad y autenticidad
Difusión de software dañino y secuestro de datos	[A.8]	Adjunto o enlace malicioso; credencial de acceso remoto previamente comprometida	Disponibilidad, integridad y confidencialidad
Explotación de vulnerabilidades sin corregir	[E.20], [A.11]	Servicio publicado en Internet que no ha recibido las actualizaciones de seguridad	Confidencialidad, integridad y disponibilidad
Ataque a la cadena de suministro	[A.22], [A.8]	Componente de software de terceros o proveedor de servicios de tecnología con acceso a la red	Integridad, confidencialidad y disponibilidad
Denegación de servicio	[A.24]	Saturación deliberada del enlace de comunicaciones o del servicio publicado	Disponibilidad
Uso de credenciales filtradas	[A.5], [A.11]	Credenciales expuestas en repositorios públicos o procedentes de filtraciones de otros servicios	Confidencialidad, autenticidad y trazabilidad
Robo de equipos y de soportes de información	[A.25]	Sustracción de un equipo portátil, de un teléfono o de un disco de respaldo fuera de las instalaciones	Confidencialidad y disponibilidad
Fraude por suplantación del correo corporativo	[A.5]	Mensaje que imita a un directivo o a un proveedor para inducir el desvío de un pago	Autenticidad e integridad

Nota. Elaboración propia con base en el Catálogo de Elementos de MAGERIT v3.

Las amenazas anteriores comparten un número reducido de vías de acceso, y esa concentración es una noticia favorable porque permite priorizar. El correo electrónico continúa siendo el vector de entrada predominante, tanto para la

suplantación dirigida como para la difusión de software dañino. Le siguen los servicios publicados en Internet sin actualizar, los accesos remotos protegidos únicamente por contraseña, las credenciales reutilizadas que ya circulan en filtraciones anteriores, los dispositivos personales que se conectan a la red corporativa y los proveedores de tecnología cuyo acceso permanente rara vez se somete a revisión.

Conviene advertir que en una micro o pequeña empresa el perímetro tradicional prácticamente ha desaparecido. La información reside en servicios en la nube contratados directamente por las áreas de negocio, se procesa en equipos que salen de las instalaciones y se comparte con contadores, asesores y proveedores externos. En esas condiciones la protección no puede sostenerse sobre la defensa de un borde de red, sino sobre la identidad, el dispositivo y el dato.

La Frontera Difusa entre el Origen Interno y el Externo

La clasificación por origen, útil como criterio de ordenamiento, resulta insuficiente en el momento de diseñar controles. La razón es que el actor externo casi nunca ataca directamente al activo de información: necesita atravesar un contenedor, y con enorme frecuencia el contenedor que elige es humano. Una credencial obtenida mediante suplantación convierte al atacante externo en un usuario interno legítimo a los ojos de todos los sistemas, de manera que la amenaza es externa en su origen pero interna en su manifestación, y ningún control perimetral la detendrá a partir de ese punto.

La consecuencia metodológica es que la pregunta relevante no es de dónde procede el actor, sino qué vulnerabilidad se explota y en qué contenedor. Un mismo control puede así atender amenazas de ambos orígenes: la autenticación resistente a la suplantación protege frente al atacante externo que intenta obtener una credencial y frente al empleado que intenta actuar con la identidad de un compañero. Priorizar por vulnerabilidad explotada, y no por origen del actor, produce planes de tratamiento más eficientes.

Vulnerabilidades: Tipología y Valoración de la Criticidad

Si las amenazas no pueden eliminarse, la capacidad real de actuación de la organización se concentra en las vulnerabilidades. Este apartado las clasifica según su naturaleza y propone criterios para valorar su criticidad, de modo que la corrección pueda ordenarse conforme al riesgo que cada una habilita y no conforme a la facilidad con que se detecta.

Tipología de Vulnerabilidades

Una clasificación operativa de las vulnerabilidades debe permitir asignar cada debilidad a la capa de defensa que le corresponde, porque de esa asignación depende quién es responsable de corregirla. La Tabla 13 presenta la agrupación en cuatro tipos que cumple ese propósito.

Tabla 13. Tipología de vulnerabilidades y capa de defensa asociada

Tipo	Descripción	Ejemplos frecuentes	Capa de defensa
Técnicas	Debilidades en el software, en su configuración o en la arquitectura de los sistemas	Sistemas sin actualizaciones, credenciales por defecto, ausencia de cifrado en respaldos, puertos de administración expuestos	Aplicación, equipo y red
Humanas	Debilidades en el conocimiento, el comportamiento o la susceptibilidad de las personas	Desconocimiento de técnicas de engaño, contraseñas débiles o reutilizadas, ausencia de segundo factor de autenticación	Concientización y formación
Organizativas	Ausencia o insuficiencia de normativa, procesos y asignación de responsabilidades	Inexistencia de políticas de seguridad e inventario de activos, falta de proceso formal de alta y baja de personal	Políticas y procedimientos
Físicas	Debilidades en la protección del entorno	Acceso no controlado al área del servidor, ausencia	Seguridad física

Tipo	Descripción	Ejemplos frecuentes	Capa de defensa
	donde residen los activos	de respaldo de energía, equipos sin custodia ni cifrado	

Nota. Elaboración propia, correspondencia con las capas del modelo de seguridad por profundidad.

La distribución de esfuerzos entre estos cuatro tipos suele estar desequilibrada. Las vulnerabilidades técnicas concentran la atención porque son las más visibles y las que las herramientas automatizadas detectan, mientras que las organizativas, que son las que habilitan el mayor número de amenazas simultáneamente, permanecen sin corregir por no tener un responsable técnico evidente. Corregir un proceso de baja de personal no requiere inversión en tecnología, y sin embargo cierra de una sola vez varias vías de acceso.

Valoración de la Criticidad de una Vulnerabilidad

No todas las vulnerabilidades merecen la misma urgencia. Su criticidad no depende únicamente de su severidad técnica, sino de la combinación entre la facilidad con que puede ser aprovechada y el valor del activo que quedaría expuesto. Los criterios de la Tabla 14 permiten ordenar la corrección de manera razonada.

Tabla 14. Criterios para valorar la criticidad de una vulnerabilidad

Criterio	Pregunta orientadora	Efecto sobre la criticidad
Facilidad de explotación	¿Requiere conocimiento especializado o existe una herramienta pública que la aproveche de forma automática?	Aumenta cuando la explotación es trivial o automatizable
Grado de exposición	¿Es alcanzable desde Internet o únicamente desde la red interna?	Aumenta con la accesibilidad del activo vulnerable

Criterio	Pregunta orientadora	Efecto sobre la criticidad
Privilegio requerido	¿Necesita el actor disponer de credenciales previas para aprovecharla?	Disminuye cuando exige privilegios elevados o acceso local
Dimensiones comprometidas	¿Cuántas de las cinco dimensiones de seguridad se degradan y en qué grado?	Aumenta con el número y la severidad de las dimensiones afectadas
Valor del activo alcanzable	¿Cuál es el valor, propio o acumulado, del activo que quedaría expuesto?	Aumenta de forma proporcional al valor del activo
Control compensatorio	¿Existe otro control que limite el aprovechamiento aunque la debilidad persista?	Disminuye cuando la defensa en profundidad es efectiva

Nota. Elaboración propia con base en MAGERIT v3 e ISO/IEC 27005.

Para las vulnerabilidades de naturaleza técnica existe además un instrumento cuantitativo de amplia aceptación, el Sistema Común de Puntuación de Vulnerabilidades (CVSS), que asigna a cada debilidad conocida una calificación de 0 a 10 a partir de criterios equivalentes a los de la tabla anterior, con bandas que van de baja a crítica. Su empleo aporta objetividad y comparabilidad, y permite además fijar plazos máximos de corrección por banda de severidad, que es la forma más práctica de convertir la valoración en una obligación verificable.

Debe advertirse, no obstante, su límite: esa puntuación solo aplica a vulnerabilidades técnicas publicadas y catalogadas. Las vulnerabilidades humanas y organizativas, que son precisamente las de mayor peso en una organización pequeña, no disponen de una calificación equivalente y deben valorarse mediante el juicio experto conforme a los criterios de la tabla anterior. Confiar la priorización exclusivamente al instrumento cuantitativo conduce, por tanto, a un plan de corrección sesgado hacia lo técnico, que deja intactas las carencias que habilitan más amenazas.

Correspondencia entre Vulnerabilidades y Amenazas

El paso final de esta etapa consiste en vincular cada vulnerabilidad identificada con las amenazas que habilita, ya que solo de ese cruce surge el riesgo que se evaluará posteriormente. La relación es de muchos a muchos y conviene documentarla de forma explícita: la ausencia de un segundo factor de autenticación, por ejemplo, habilita simultáneamente la suplantación de identidad, el acceso no autorizado, la difusión de software dañino a través de una cuenta legítima y el fraude por suplantación del correo corporativo. Cuatro amenazas de bloques distintos comparten una única debilidad.

Documentar esa correspondencia produce dos beneficios inmediatos: permite identificar las vulnerabilidades transversales, que son las candidatas naturales a encabezar el plan de tratamiento por su rendimiento en términos de reducción de riesgo, y permite detectar amenazas que quedarían sin cobertura porque ninguna vulnerabilidad identificada las habilita, lo que suele indicar no una fortaleza real sino una omisión en la fase de identificación.

Comparación entre el Origen Interno y el Origen Externo

Recogidas ya las características de ambos orígenes, la comparación sistemática permite fundamentar la selección de controles. La Tabla 15 contrasta ambos tipos de amenaza en los criterios de mayor relevancia para el diseño de la protección.

Tabla 15. Comparación entre amenazas de origen interno y de origen externo

Criterio de comparación	Amenaza de origen interno	Amenaza de origen externo
Conocimiento del entorno	Elevado: conoce los procesos, los sistemas y dónde reside la información de valor	Reducido al inicio: requiere una fase previa de reconocimiento
Necesidad de vencer el perímetro	Ninguna: el actor ya se encuentra dentro con acceso legítimo	Elevada: debe obtener un punto de entrada antes de actuar
Facilidad de detección	Baja: la acción se ejecuta dentro de lo que las credenciales autorizan y no se registra como anomalía	Mayor: los controles de perímetro y de detección están diseñados precisamente para este supuesto
Motivación predominante	Beneficio propio o agravio laboral y, con mucha mayor frecuencia, simple negligencia	Beneficio económico a escala, ventaja competitiva, activismo o espionaje
Eficacia de los controles de perímetro	Reducida: el cortafuegos no observa el abuso de un acceso autorizado	Alta: constituyen la primera línea de defensa
Controles más eficaces	Segregación de funciones, mínimo privilegio, trazabilidad independiente, proceso formal de baja, supervisión	Autenticación resistente a la suplantación, gestión de actualizaciones, filtrado de correo, segmentación de la red
Frecuencia relativa	Alta, de forma destacada en su variante negligente	Muy alta en volumen de intentos, considerablemente menor en compromisos efectivos
Impacto unitario	Elevado cuando es deliberada, por el nivel de acceso del que ya dispone el actor	Muy elevado en los casos de secuestro de datos o de compromiso de la cadena de suministro

Nota. Elaboración propia.

Del contraste se desprenden tres orientaciones para la etapa siguiente del proyecto. La primera es que ambos orígenes requieren familias de control distintas y no sustituibles entre sí: invertir exclusivamente en defensa de perímetro deja sin atender toda la amenaza interna, mientras que atender solo la amenaza interna deja abierta la vía de entrada. La segunda es que la amenaza interna resulta más difícil

de detectar precisamente porque se ejecuta dentro de lo autorizado, lo que confiere a la trazabilidad un valor superior al que suele reconocérsele: sin registros fuera del alcance de quien opera el sistema, la organización no solo no previene el abuso, sino que tampoco puede demostrarlo después.

La tercera orientación, y la más relevante para el diseño del plan de tratamiento, es que la frontera entre ambos orígenes se cruza con facilidad a través del contenedor humano. Por esa razón las vulnerabilidades de tipo humano y organizativo, aun careciendo de una calificación técnica que las haga visibles en las herramientas, concentran el mayor rendimiento de la inversión en seguridad: son las que un mismo control permite cerrar frente a actores de ambos orígenes de manera simultánea.

Conclusiones

El estudio de MAGERIT permite reconocer sus principales fortalezas: es una metodología pública, gratuita, detallada y de aplicación paso a paso, que se apoya en un catálogo normalizado de activos, amenazas y salvaguardas y en una herramienta de cálculo especializada. Su enfoque cuantitativo-cualitativo y su alineación con las normas ISO 31000 e ISO/IEC 27005 facilitan la trazabilidad de las decisiones de seguridad, aunque un análisis completo puede requerir un esfuerzo considerable en organizaciones medianas o grandes.

OCTAVE Allegro, por su parte, aporta un enfoque complementario centrado en los objetivos de negocio más que en la infraestructura tecnológica: su agilidad, su nula dependencia de herramientas técnicas en las fases iniciales y su lenguaje orientado al impacto empresarial lo hacen especialmente adecuado para organizaciones que no disponen de una estructura de seguridad consolidada, como es el caso de una micro o pequeña empresa.

En cuanto a los activos informáticos, se concluye que su valor no se mide en términos monetarios sino en función del perjuicio que su pérdida, alteración o divulgación causaría a la organización, y que la criticidad resulta de combinar ese valor con el impacto en el negocio y, de forma particularmente relevante en organizaciones pequeñas, con el nivel de confidencialidad requerido. La combinación de la taxonomía exhaustiva de MAGERIT con el enfoque simplificado de OCTAVE Allegro permite construir un inventario completo sin exigir una estructura organizacional compleja.

Respecto de las amenazas y vulnerabilidades, la investigación permite concluir que ambos elementos se relacionan de forma multiplicativa con el valor del activo para generar riesgo, y que mientras las amenazas no pueden eliminarse, las vulnerabilidades sí pueden reducirse o corregirse, razón por la cual la capacidad de acción de la organización se concentra en estas últimas. La distinción entre origen interno y externo resulta útil como criterio de ordenamiento, pero insuficiente por sí

sola para diseñar controles, ya que el actor externo frecuentemente atraviesa el contenedor humano para operar como si fuera un actor interno legítimo. De ello se desprende que priorizar por vulnerabilidad explotada y no por origen del actor produce planes de tratamiento más eficientes, y que las vulnerabilidades de tipo humano y organizativo, pese a no contar con una calificación técnica visible, concentran el mayor rendimiento de la inversión en seguridad.

En conjunto, el dominio de estos conceptos —activos, amenazas, vulnerabilidades, brechas y los modelos MAGERIT y OCTAVE Allegro— constituye la base conceptual indispensable para abordar, en la siguiente etapa del proyecto grupal, la estimación del impacto y del riesgo, y la definición de un plan de tratamiento fundamentado y priorizado para una micro o pequeña empresa.

Referencias

- Caralli, R. A., Stevens, J. F., Young, L. R., y Wilson, W. R. (2007). Introducing OCTAVE Allegro: Improving the information security risk assessment process. Software Engineering Institute, Carnegie Mellon University.
- Centro Criptológico Nacional. (s. f.). PILAR: Procedimiento Informático-Lógico para el Análisis de Riesgos. Gobierno de España. <https://www.pilar.ccn-cert.cni.es/>
- Forum of Incident Response and Security Teams. (2019). Common Vulnerability Scoring System version 3.1: Specification document. FIRST. <https://www.first.org/cvss/>
- International Organization for Standardization. (2018). ISO/IEC 27005: Information technology — Security techniques — Information security risk management. ISO.
- International Organization for Standardization. (2022). ISO/IEC 27001: Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
- Ministerio de Hacienda y Administraciones Públicas. (2012a). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método. Gobierno de España.
- Ministerio de Hacienda y Administraciones Públicas. (2012b). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro II: Catálogo de Elementos. Gobierno de España.
- Ministerio de Hacienda y Administraciones Públicas. (2012c). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro III: Guía de Técnicas. Gobierno de España.

MITRE Corporation. (s. f.). MITRE ATT&CK: Enterprise matrix.

<https://attack.mitre.org/>

National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30, Rev. 1). U.S. Department of Commerce.

Organización Internacional de Normalización. (2018). ISO 31000:2018. Gestión del riesgo — Directrices. ISO.

OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. <https://owasp.org/Top10/>

Seifti. (2024). Magerit: Metodología de análisis y gestión de riesgos.

<https://seifti.io/es/magerit/>

WeLiveSecurity. (2022). 8 pasos para la evaluación de riesgos de ciberseguridad de una empresa (parte I). ESET. <https://www.welivesecurity.com/la-es/2022/12/13/8-pasos-evaluacion-de-riesgos-1/>

Anexos

A continuación se presenta, a manera de anexo, un ejemplo aplicado del perfil de activo de información conforme a la metodología OCTAVE Allegro, correspondiente a la Fase 2 del proceso (Desarrollar el Perfil del Activo e Identificar Contenedores). El ejemplo ilustra cómo se documentan en la práctica los requerimientos de seguridad y los contenedores de un activo crítico.

Tabla 16. Ejemplo de perfil de activo de información (OCTAVE Allegro)

Atributo del perfil	Detalle del activo
Activo de información	Base de datos de reportes de cumplimiento y vulnerabilidades de clientes
Descripción	Registros detallados que contienen las brechas de seguridad, resultados de auditorías automatizadas y configuraciones de infraestructura de los clientes de la organización
Justificación de prioridad	Es el núcleo del valor del negocio; su exposición destruiría la confianza de los clientes, provocando fuga de usuarios y posibles demandas por negligencia en el manejo de datos sensibles
Dueño del activo	Director de Cumplimiento, o el líder de producto del área de negocio, no el gerente de TI
Requerimiento de confidencialidad	Alto: solo el cliente propietario y el personal de soporte de nivel 3, mediante autenticación multifactor y conexión VPN, deben tener acceso a estos reportes
Requerimiento de integridad	Alto: los datos de auditoría no pueden ser alterados, ya que los clientes los utilizan para justificar certificaciones normativas, por ejemplo ISO 27001
Requerimiento de disponibilidad	Medio: se requiere acceso constante para las operaciones del cliente, pero una interrupción de cuatro horas no quiebra el negocio ni pone en riesgo la vida humana
Requerimiento más crítico	Confidencialidad

Nota. Elaboración propia con base en la estructura de perfil de activo de OCTAVE Allegro (Caralli et al., 2007).

Complementando el perfil anterior, la tabla siguiente documenta el mapa de contenedores del activo, es decir, los lugares físicos, técnicos o humanos donde la información reside, se transporta o se procesa.

Tabla 17. Ejemplo de mapa de contenedores (OCTAVE Allegro)

Tipo de contenedor	Dónde reside o se procesa el activo
Contenedores técnicos	Servidor de base de datos en producción (clúster en nube); servidores de respaldo de almacenamiento; túneles de transmisión de datos mediante APIs REST
Contenedores físicos	Centro de datos del proveedor de la nube; computadoras portátiles del equipo de soporte cuando descargan fragmentos de registros para depuración
Contenedores humanos	Ingenieros de bases de datos; analistas de soporte técnico; terceros o proveedores de servicios gestionados

Nota. Elaboración propia con base en la estructura de perfil de activo de OCTAVE Allegro (Caralli et al., 2007).

Nota clave sobre la ejecución: el error más común al llenar esta matriz es que el área de tecnología la complete en solitario. La decisión de cuál requerimiento de seguridad es el «más crítico» debe provenir del dueño del activo, porque esa decisión determina hacia dónde se orienta el presupuesto de seguridad del período siguiente.